

1) objective and methodology:

An organization has commissioned an external penetration test to determine how much information an unauthorized attacker could gather about its internal-facing infrastructure without directly attacking its system. using theHarvester against the authorized domain tesla.com, conduct a comprehensive reconnaissance exercise to identify publicly available email address, subdomains, IP address, URLs, and other relevant infrastructure

Required tool:- theHarvester.

commands used:-

- 1) theHarvester -d tesla.com -b hackertarget
- 2) theHarvester -d tesla.com -b hackertarget -f tesla-hackertarget
- 3) ls -lh tesla-hackertarget*
- 4) theHarvester -d tesla.com -b hackertarget | tee tesla-hackertarget.txt
- 5) jq . tesla-hackertarget.json | less

output:-

① *) accounts. tesla.com : 23.222.124.64

*) am813 - gpwl. tesla.com : 199.120.50.30

*) api - api.eng.rm.cloud.tesla.com : 66.17.26.29

1) auth. eng. use. vn cloud. test. com : 66.17.8.3

2)

2) accounts. test. com : 23.222.124.64

+) akamai - api gateway - vehicle extn bgw - pidsrc-st. test. com :
23.62.10.65

*) am13 - gpwl. test. com : 199.120.50.30

+) apac - cppm. test. com : 23.202.44.97

3)

-rw-r--r-- 1 kali kali 3.4K Aug 19 09:12 test-backup
target. idon

-rw-r--r-- 1 kali kali 6.1K Aug 19 09:12 test-backup
target.xml

4)

+) accounts. test. com : 23.222.124.64

+) akamai - api gateway - vehicle extn bgw - pidsrc-st. test. com :
23.62.10.65

2) am13 - gpwl. test. com : 199.120.50.30

+) apac - cppm. test. com : 23.202.44.97

② objective and methodology:

A penetration test was carried out against the publicly accessible, intentionally vulnerable web application `test.php.vulnweb.com` using nikto to identify exposed files and directories, insecure HTTP methods, server configuration weaknesses, information disclosure issues, outdated components, and dangerous files.

Required tool:- Nikto

Commands used :-

- 1) `nikto -h http://test.php.vulnweb.com`
- 2) `nikto -h http://test.php.vulnweb.com -o nikto-testphp-report.html`
-o - Format output
- 3) `nikto -h http://test.php.vulnweb.com -Tuning 1,2,3,4,6,9`
- 4) `cat nikto-testphp-report.html | less`

output:

① banner and header findings:-

- + Nikto v2. X scan on testphp.vulnweb.com
- + server: nginx C banner captured from the first run
- + The X-Content-Type-Options header is not set
- + The anti-clickjacking X-Frame-Options header is not present

* Cookie persistence created without the help of flag

② File/ directory

+ Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE

+ /admin/: Admin login page/section found.

+ /crs/entries or /src/entries: version control metadata file found.

+ cookie persistence found for one or more folders

③ outdated component

+ outdated version of php detected in server/x-powered-by header

+ /listproducts.php?cat=1: possible SQL-injection entry point

+ /search.php?test=query: reflected parameter observed

④ confirms and consolidated :-

+ 6144 requests: 0 errors (s) and 4141 (s) reported.

+ 100% success rate for all requests.

+ 100% success rate for all requests.

+ 100% success rate for all requests.

+ 100% success rate for all requests.

③

objective and methodology:-

An external DNS security assessment was performed against the authorized target domain zone transfer .me using the dig utility, to enumerate all standard DNS record types, identify the authoritative name servers, and determine whether an unauthorized zone transfer (AXFR) could be performed. zone transfer .me is a domain deliberately maintained with a purpose.

Required tool:- Dig

Commands:-

- 1) dig A zone transfer .me
- 2) dig MX zone transfer .me
- 3) dig NS zone transfer .me
- 4) dig TXT zone transfer .me
- 5) dig SOA zone transfer .me
- 6) dig axfr zone transfer .me @ns2tiny.dig.ninja.

output:-

① A record:-

:: ANSWER SECTION:

zone transfer .me. 7200 IN A <resolved IP from hiro runs>

② MX record

* zone transfer.me. 7200 IN MX 0 ASPMX.L- Google.com.

③ NS Record:-

zone transfer.me. 7200 IN NS nsz1m1.dig1.ninja.

zone transfer.me. 7200 IN NS nsz1m2.dig1.ninja.

4) TXT record:-

zone transfer.me. 7200 IN TXT "<informational txt string
from live run>"

5) SOA record:

zone transfer.me. 7200 IN SOA nsz1m1.dig1.ninja. robin.dig1.
ninja. <serial> <refresh> <retry> <expire> <minimum>

6) AXFR zone transfer attempt:-

:: Transfer succeeds

www.zone transfer.me. IN A <ip>

office.zone transfer.me. IN A <ip>

internal.zone transfer.me. IN A <ip>

mail.zone transfer.me IN A <ip>

... Complete list of zone records returned in one response.

④ Objective and methodology:-

Window/SMB target 192.168.1.100 using Enum4linux, to determine what information could be obtained through SMB and not BIOS enumeration before any exploration was attempted. Enum4linux automates the classic null-session and PIP-cycling enumeration techniques against SMB.

Required tool:- Enum4linux

Commands:-

- 1) Enum4linux -a 192.168.1.100
- 2) Enum4linux -v 192.168.1.100
- 3) Enum4linux -s 192.168.1.100
- 4) Enum4linux -p 192.168.1.100
- 5) Enum4linux -a 192.168.1.100 | tee Enum4linux-192-168-1-100.txt

Output:-

① -a, full enumeration)

- * domain/work group name: WORKGROUP
- * server os: <SMB> negotiated as string from line runs
- * server is functioning as a file/print server only.

⑥ - users

S-1-1-21-...-100 wopcarup / administrator

S-1-1-21-...-1001 wopcarup / src backup

S-1-1-21-...-1002 wopcarup / guest

⑦ - s. shares

share name	Type	comment	Access
ADMIN	disk	Remote Admin	NO Access (needs credentials)
Public	disk		READ/WRITE & accessible via anonymous session

⑧ - P. Password policy.

- * minimum password length : 0
- * password complexity flag : off
- * Account lockout threshold : none

⑨ Enum4linux - 192.168.1.100.txt

(Same content as command 1, written to file)

⑤ Objective and methodology:

Scanme.org.nmap, the official test host maintained by the Nmap project for scanning practice. Using Netcat to connect directly to accessible TCP services and capture the banner/response each service discloses. Open ports were first identified with a quick Nmap Scan, and Netcat was then used against each open port.

Required tool:- Netcat (nc)

Commands:-

- 1) `nmap -p - --open -TH - Scanme.nmap.org`
- 2) `nc -v Scanme.nmap.org 22`
- 3) `printf 'HEAD /HTTP/1.0\r\n\r\n' | nc -v Scanme.nmap.org 80`
- 4) `nc -v Scanme.nmap.org 21`

Output

① Nmap port discovery

PORT STATE SERVICE

22/tcp open ssh

80/tcp open http

② output (SSH banner grab on port 22)

Connection to scanme.nmap.org 22 port [tcp/ssh] successful

SSH-2.0-openssh <version captured from live nmap scan>

③ HTTP header grab on port 80

HTTP/1.1 200 OK

Server: Apache/ <version captured from live run> (cos)

④ port 21 probe

no: Connect to scanme.nmap.org port 21 (ftp) failed.

Connection refused.